PRIVILEGE ESCALATION SIMULATION

Tshepang Suping

Table of Contents

Privilege Escalation 2
How does it work? 2
Types of Privilege Escalation 2
Vertical Privilege Escalation 2
Horizontal Privilege Escalation 2
The step-by-step process on how to execute a privilege escalation attack. 3
Step 1: Reconnaissance 3
Step 2: Execution of the Escalation 5
References 6

Privilege Escalation

A cyberattack designed to gain unauthorized privileged access into a system is a privilege escalation attack. The attackers exploit vulnerabilities in operating systems to gain elevated access (Lenaerts-Bergmans, 2022).

How does it work?

Privilege escalation basically happens in three steps:

1. ***Attackers gain initial access***: through weak credentials, malware and phishing (Legit Security, 2024) .
2. ***Attackers identify system vulnerabilities***: and use those vulnerabilities to gain more access and bypass security measures (Legit Security, 2024) .
3. ***Attackers use administrative access***: to take advantage of the elevated access to change critical settings (Legit Security, 2024) .

Types of Privilege Escalation

Privilege Escalation attack falls into two categories: vertical and horizontal. The categories define where the attackers aim to increase their access rights or to simply misuse the access of another account with a similar permission level. Each category exploit different vulnerabilities in the system (Legit Security, 2024) .

Vertical Privilege Escalation

A vertical privilege escalation occurs when a threat actor obtains higher-level permissions, by exploiting flaws in the system or inadequate authentication methods. It grants attackers administrative power which is dangerous as it means they can disable servers, deploy malware and steal data. They can also gain hidden access which would let them take control of the system in the future (Legit Security, 2024) .

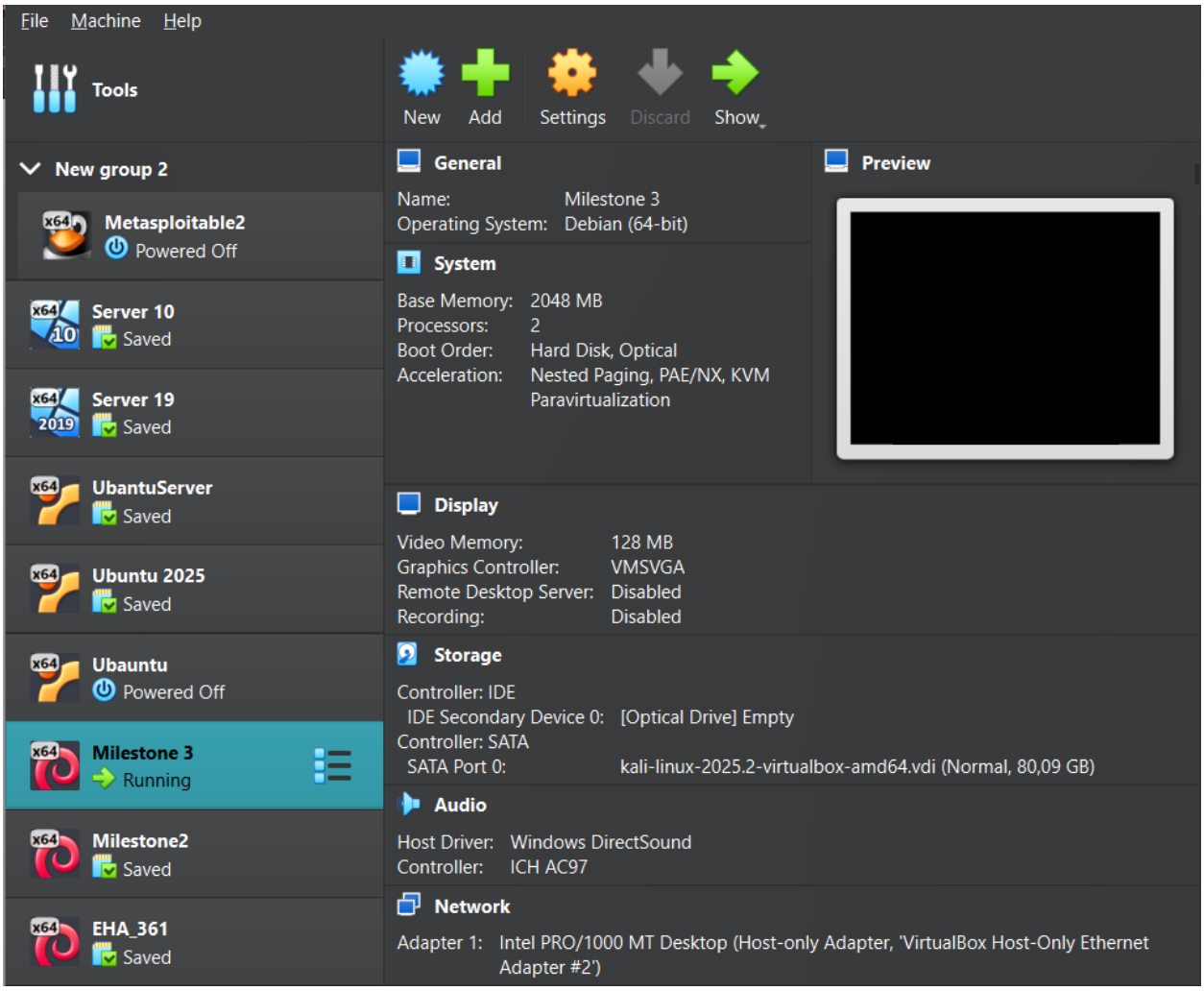
Horizontal Privilege Escalation

A horizontal privilege escalation occurs when an attacker makes use of the correct credentials to access sensitive data or resources. Cybercriminals use horizontal privilege escalation to exploit users' access rights, to steal data or even carry out unauthorized actions without escalaring to higher privileges (Legit Security, 2024).

The step-by-step process on how to execute a privilege escalation attack.

Step 1: Reconnaissance

Virtual Machine set up, Milestone 3.



Before running any line of code we first have to verify that we are in the kali terminal.

```
┌──(kali㉿kali)-[~]
└─$ whoami
kali

┌──(kali㉿kali)-[~]
└─$ id
uid=1000(kali) gid=1000(kali) groups=1000(kali),4(adm),20(dialout),24(cdrom),25(flopp
y),27(sudo),29(audio),30(dip),44(video),46(plugdev),100(users),101(netdev),103(scanne
r),107(bluetooth),125(lpadmin),133(wireshark),135(kaboxer),136(vboxsf)
```

The code **whoami** is used to verify we are indeed in the kali terminal and return username of the current user (IBM, 2025).

The purpose of the code **id** is to show the real User IDs and Group IDs (IBM, 2024).

```
┌──(kali㉿kali)-[~]
└─$ sudo -l
Matching Defaults entries for kali on kali:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
    use_pty

User kali may run the following commands on kali:
    (ALL : ALL) ALL
```

The purpose of this code **sudo -l** is to list the allowed commands for calling user on the current host.

As shown, the user has **(ALL : ALL) ALL** in the sudoers file which is a problem because then it allows the possibility of the execution of all commands.

The attacker can immediately gain full control of the operating system by simply calling sudo if a low-privileged account is compromised.

Step 2: Execution of the Escalation

This command, **sudo find . -exec /bin/sh -p \; -quit ,** is risky because if the attacker has access to sudo rights to run find without a password then this command can bypass normal privilege restrictions and give the attacker access to a root shell.

The code used **sudo find . -exec /bin/sh -p \; -quit** (GTFOBins, 2025)**.**

Explanation of the code:

sudo find . : runs the **find** command as root beginning from the current directory

-exec : tells the **find** to run a system command

/bin/sh -p : spawns a shell. The -p (privileged) flag ensures the shell does not immediately drop the root permissions.

-quit : it only spawns one shell so it stops **find** after the first match .

References

GTFOBins, 2025. *GTFOBins*. [Online]
Available at: https://gtfobins.org/
[Accessed 28 February 2026].

IBM, 2024. *id Command*. [Online]
Available at: https://www.ibm.com/docs/en/aix/7.1.0?topic=i-id-command
[Accessed 28 February 2026].

IBM, 2025. *whoami - Display your effective user name*. [Online]
Available at: https://www.ibm.com/docs/en/zos/3.1.0?topic=descriptions-whoami-display-your-effective-user-name
[Accessed 28 February 2026].

Legit Security, 2024. *What Is Privilege Escalation? Types, Examples, and Prevention*. [Online]
Available at: https://www.legitsecurity.com/aspm-knowledge-base/what-is-privilege-escalation
[Accessed 26 February 2025].

Lenaerts-Bergmans, B., 2022. *What is Privilege Escalation?*. [Online]
Available at: https://www.crowdstrike.com/en-us/cybersecurity-101/cyberattacks/privilege-escalation/
[Accessed 26 February 2026].

pebble, 2025. *How Hackers Gain Root Access | Linux Privilege Escalation*. [Online]
Available at: https://www.youtube.com/watch?v=RFebj52xrLU
[Accessed 28 February 2026].